

SecSuite: Modular Cybersecurity Suite

Kısıtlar ve Etkiler Dökümanı

Umut Bayram, Archyn Mikhailov, Kıvanç Taş, Yiğit Sarı

1) Standartlara Uyum Özeti

SecSuite projesi, BİL496 aşamasında yazılım mühendisliği standartlarına büyük ölçüde uygun biçimde geliştirilmiştir. Low-Level Design dokümanında da görüldüğü üzere sistem; TypeScript strict mode, RESTful API yaklaşımı, Zod tabanlı doğrulama, OpenAPI sözleşme üretimi, modüler monorepo yapısı ve çok katmanlı edge mimari ilkeleri doğrultusunda tasarlanmıştır. Backend, istemci uygulamaları ve AI engine katmanlarının birbirinden ayrılması; veri sözleşmelerinin açık biçimde tanımlanması; kimlik doğrulama, oran sınırlama, önbellekleme ve asenkron işleme gibi kritik işlevlerin belirli kurallara bağlı olarak uygulanması, projenin teknik açıdan olgun ve mühendislik disiplini içinde geliştirildiğini göstermektedir. Bununla birlikte, performans standardı bakımından tam uyum sağlandığı söylenemez. Test planında bot dışındaki modüller için 8 saniyelik yanıt süresi hedefi tanımlanmış olmasına rağmen final rapordaki güncel sonuçlarda TC-10 ve TC-20 testleri başarısız görünmektedir. Bu nedenle proje genel olarak standartlara uyumlu olmakla birlikte, performans/SLA boyutunda **kısmi uyum** göstermektedir.

Standart / İlke	Projede Nasıl Uygulandı?	Durum	Kanıt / Referans
Tip güvenliği ve kod standardı	Backend ve client kodu TypeScript strict mode ile geliştirildi; dosya adlandırma, export yapısı ve kod düzeni için belirli kurallar kullanıldı.	Uyumlu	LLD 1.4; TypeScript strict mode, naming rules, build standards
API sözleşmesi ve doğrulama standardı	API giriş/çıkışları Zod ile doğrulandı, OpenAPI üretimi ile sözleşmeler dokümante edildi.	Uyumlu	LLD 1.4, 3.2, 3.3
Güvenli kimlik doğrulama ve erişim kontrolü	Session/API key auth, rate limiting, CAPTCHA, visibility control ve API key yönetimi uygulanmıştır.	Uyumlu	LLD 3.3, 15, 16; Test Plan security/auth testleri
Asenkron ve güvenilir işleme standardı	Uzun süren analizler queue üzerinden işlendi; SSE ile durum bildirimi sağlandı; retry mantığı kullanıldı.	Uyumlu	LLD 2.1.3, 2.1.4, 3.9, 17

Test mühendisliği yaklaşımı	Unit, integration, system, performance, security ve UAT seviyelerinde test planı hazırlanmış; 42 test case tanımlanmıştır.	Kısmi uyum	Test Plan 4.1–4.6; 42 test case
Performans/SLA uyumu	Bot dışındaki modüller için 8 sn, bot modülü için 10 sn hedefi tanımlandı; ancak tüm modüller bu hedefi tam sağlayamadı.	Kısmi uyum	Test Plan performance criteria; TC-10 ve TC-20 sonucu
Dokümantasyon ve izlenebilirlik	LLD, Test Plan ve Final Report ayrı belgeler halinde hazırlanmış; requirement-to-test mantığı kurulmuştur.	Uyumlu	LLD + Test Plan + Final Report yapısı

2) Kısıtların Yönetimi Özeti

Projenin en belirgin kısıtları; edge ortamının teknik sınırları, model eğitimi için gereken yüksek hesaplama gücü, üçüncü taraf servislere bağımlılık ve proje kapsamının genişliğidir. Cloudflare Workers mimarisi düşük gecikmeli küresel erişim sağlasa da bellek ve CPU açısından sınırlı bir çalışma ortamı sunduğundan, ağır makine öğrenmesi işlemleri doğrudan edge katmanında değil, ayrı bir FastAPI tabanlı AI engine üzerinde yürütülmüştür. Bu karar, kaynak kısıtını doğrudan mimari ayrışma ile yönetme açısından doğru bir mühendislik yaklaşımı olmuştur. Model eğitimi sürecinde ise yerel donanımın yetersiz kaldığı noktalarda Google Colab ve Amazon AWS kullanılarak çalışmalar sürdürülmüş, böylece özellikle transformer tabanlı modellerin eğitimi ve deneysel iterasyonları sürdürülebilir hâle getirilmiştir. Ayrıca dış servis kaynaklı gecikmeler ve altyapı değişkenliği; queue tabanlı işleme, iki katmanlı cache ve deduplication mekanizmalarıyla azaltılmaya çalışılmıştır. Ancak final test sonuçlarında görülen performans sapmaları, bu kısıtların tamamen ortadan kaldırılamadığını göstermektedir. Sonuç olarak proje kapsamı korunmuş, ancak bazı performans riskleri nihai sürüme kadar taşınmıştır.

Kısıt	BİL495'te Beklenen / Tanımlanan Risk	BİL496'da Fiilen Ne Yapıldı?	Sapma / Sonuç / Öğrenim
Cloudflare Workers kaynak kısıtı	128 MB memory ve sınırlı CPU süresi nedeniyle ağır inference edge üzerinde doğrudan çalışamayabilir.	ML inference ayrı FastAPI AI engine'e taşındı; Worker katmanı orkestrasyon, auth, cache ve routing için kullanıldı.	Başarılı yönetildi. Mimari ayrıştırma doğru karardı; edge katman hafif tutuldu.
Dış servis ve ağ gecikmesi	VirusTotal, Google Safe Browsing, WHOIS/DNS gibi harici servisler gecikme ve rate limit riski oluşturur.	Queue, cache, deduplication ve kısmi fallback yaklaşımı uygulandı.	Kısmi başarı. Fonksiyonel doğruluk korundu; ancak response-time tarafında bazı testler hedefi aşmıştır.

SLA / performans kısıtı	Bot dışı modüllerde ≤ 8 sn, bot modülünde ≤ 10 sn hedefi vardı.	Çeşitli optimizasyonlar yapıldı; yine de bazı modüller hedef süreyi aşmıştır.	Sapma var. TC-10 ve TC-20 fail; öğrenim: doğruluk kadar latency de ayrı mühendislik problemi.
GPU / inference altyapısı değişkenliği	Paylaşımlı GPU ve cloud kaynakları ölçüm sonuçlarını dalgalandırabilir.	Performans testleri kontrollü staging ortamında yürütüldü; ancak kaynak değişkenliği tamamen ortadan kaldırılamadı.	Kısmi başarı. Ölçümler temsil edici ama mutlak değil.
Gizlilik / veri işleme kısıtı	URL, email ve article verileri kişisel veri veya hassas içerik barındırabilir.	Deduplication ve cache ile gereksiz dış servis sorguları azaltıldı; visibility control ve auth katmanı kuruldu.	Başarılı yönetildi. Ancak yanlış pozitiflerin itibar riski tamamen ortadan kalkmamıştır.
Zaman ve kapsam kısıtı	Web + desktop + SDK + 4 ana analiz modülü geniş kapsam yaratmaktadır.	Çekirdek fonksiyonellik önceliklendirildi; bazı gelişmiş optimizasyonlar ve genişletmeler future work'e bırakıldı.	Doğal scope trade-off. Fonksiyonel kapsam geniş, ancak tam SLA uyumu henüz tamamlanmadı.

3) Beklenen ve Gerçekleşen Etki Sonuçları

Projeden beklenen temel etki, farklı siber tehdit türlerini tek bir platform altında birleştirilerek kullanıcıya daha bütünleşik, erişilebilir ve açıklanabilir bir güvenlik deneyimi sunmaktır. BİL496 sonunda bu hedef büyük ölçüde gerçekleşmiştir. SecSuite; phishing e-posta analizi, sahte haber tespiti, zararlı bağlantı değerlendirmesi ve bot analizi gibi farklı işlevleri ortak bir mimari altında toplamış, böylece kullanıcıların farklı araçlar arasında geçiş yapma ihtiyacını azaltmıştır. Ekonomik açıdan bu yapı manuel analiz yükünü düşürme potansiyeli taşımaktadır. Sosyal açıdan anonymous kullanım, çoklu istemci desteği ve açıklanabilir sonuçlar kullanıcı erişimini kolaylaştırmaktadır. Çevresel açıdan ise iki katmanlı cache ve tekrar eden girdiler için deduplication yaklaşımı, gereksiz yeniden hesaplamaları azaltmaktadır. En somut gerçekleşen etki güvenlik alanındadır: test planındaki 42 testin güncel final rapora göre 40'inin geçmesi, sistemin fonksiyonel olarak güçlü bir aşamaya ulaştığını göstermektedir. Bununla birlikte, TC-10 ve TC-20'de görülen performans başarısızlıkları, gelecekte iyileştirilmesi gereken en önemli alanın düşük gecikmeli çalışma hedefi olduğunu ortaya koymaktadır.

Etki Alanı	Beklenen Etki	BİL496 Sonunda Gerçekleşen / Gözlenen Sonuç	Kanıt Türü
------------	---------------	---	------------

Ekonomik	Manuel güvenlik analiz maliyetini düşürmek; URL, email ve article incelemesini tek platformda birleştirmek	Çok kaynaklı analiz tek akışta sunuldu; manuel WHOIS, VT, DNS, SSL, screenshot gibi adımlar merkezi hale geldi.	Mimari açıklama, modül çıktıları, test kapsamı
Sosyal	Son kullanıcıların şüpheli içerikleri daha kolay değerlendirmesi; erişim bariyerini düşürmek	Anonymous kullanım, web/desktop desteği ve açıklanabilir sonuçlar sayesinde erişilebilirlik arttı.	UI akışı, auth/guest desteği, history/visibility
Çevresel	Tekrarlı analizleri azaltarak gereksiz hesaplama maliyetini düşürmek	KV + D1 cache ile aynı input tekrar işlendiğinde yeniden inference ihtiyacı azaltıldı.	Cache ve deduplication tasarımı, TC-35/TC-36
Hukuki / Etik	Kullanıcı verisini daha kontrollü işlemek; analiz kararlarını açıklanabilir kılmak	Dış servis sorguları cache ile azaltıldı; detaylı risk faktörleri ve source-level output ile kararların izlenebilirliği artırıldı.	Privacy/ethics discussion, explainable output
Sağlık	Doğrudan sağlık çıktısı hedeflenmedi; dijital güvenlik kaynaklı stres ve zarar riskini dolaylı azaltmak	Klinik/sağlık odaklı bir ölçüm yok; etki dolaylı ve nitel düzeydedir.	Nitel değerlendirme
Güvenlik	Phishing, bot, fake news ve malicious URL tehditlerini tek çatı altında tespit etmek	42 test case'in büyük çoğunluğu geçti; auth, rate limiting, XSS/SQLi, TLS, caching ve history gibi çapraz güvenlik özellikleri doğrulandı.	Test sonuçları, security testleri